

The nixpkgs security tracker

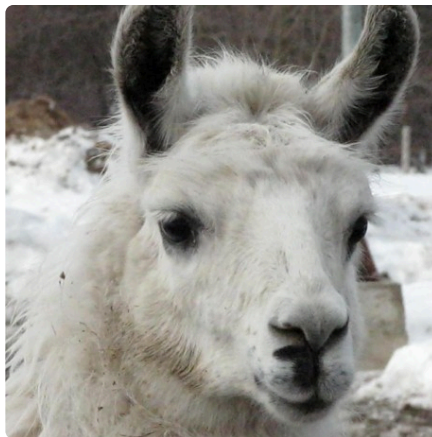
What it is and a bit of context

<https://tracker.security.nixos.org>

2026-09-11

Who am I?

- Thomas Gerbet /  @LeSuisse
- nixpkgs committer
- NixOS/nixpkgs security team member



A bit of context

- nixpkgs is pretty large
- 2 (or 3...) branches to maintain
- How do we keep everything as secure as possible?

Ancestor

- Vulnerability Roundup (example)

- End in 2022

- Allowed to surface non trivial issues:
 - Matching known vulnerabilities to packages is not easy
 - Keeping track of the issues can be challenging
 - Making the process fast and sustainable for everyone is also hard

Situation did not improve...

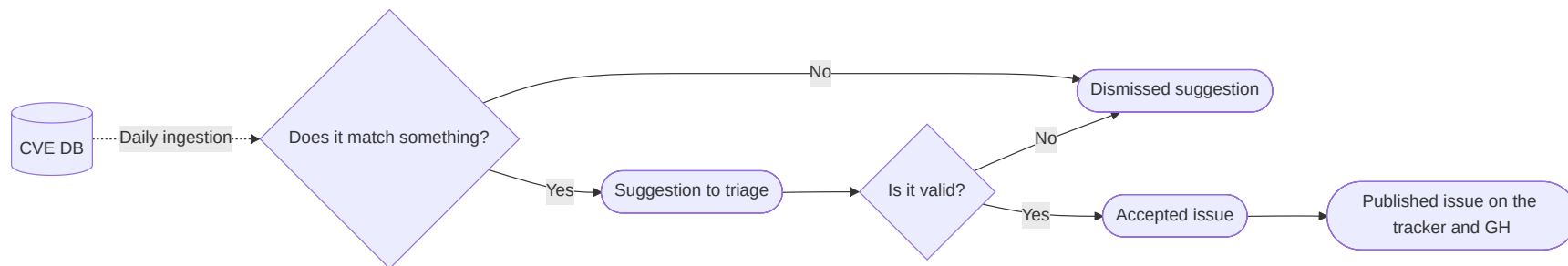
Birth of the nixpkgs security tracker

- Start back in 2023 with Sovereign Tech Fund funding
- Production usage starts in October 2025
- Currently maintained and funded by Tweag



How does it work?

High level overview



How can you help as maintainers/committers?

- Subscribe to the notifications of packages you maintain
 - You can get email notification when a potential match is identified
- Triage the issues for the packages you maintain
- Fix and backport to the stable branch the published issues

Nixpkgs security notification: CVE-2026-44310  

noreply-securitytracker@nixos.org

À thomas ▼

Hello LeSuisse,

A vulnerability may affect packages you follow or maintain:

CVE: CVE-2026-44310

Object: gitsign --verify panics on empty-certificate PKCS7 and exits 0, bypassing exit-code callers

Details: <https://tracker.security.nixos.org/suggestions/by-id/7023/>

Affected products:

- gitsign: ==>= 0.4.0, < 0.15.0

Packages you maintain that may be affected:

- gitsign

View all notifications: <https://tracker.security.nixos.org/notifications/>

Manage email notification preferences: <https://tracker.security.nixos.org/subscriptions/>

Quick demo

What's next and questions?